Proximal attack surfaces - wireless systems

Edward Farrell

SecTalks SYD0x63 (99th)

MERCURY
INFORMATION SECURITY SERVICES

Agenda

- Intro
- Attack surfaces you say?
- Refresher on wireless & domains
- Worked examples
- Questions & petting zoo

MERCURY
INFORMATION SECURITY SERVICES

About Me?

- CEO, Mercury
- Former Industry Fellow, UNSW @Canberra
- Penetration tester
- Cyber security researcher
- ISC2 Board of directors

MERCURY
INFORMATION SECURITY SERVICES

Why this talk?

- Building on from my talks and written analysis since 2015
- We keep talking about critical infrastructure & national security from the top down without going beneath the surface
- Everyone is obsessing about “exploits” without understanding the avenue of approach. (protip, your CVE that requires local admin access may not be that extreme)
- I like to explore the world- we hack to learn, we don’t learn to hack.
- Western mindsets have gotten occupied with governance as the measurement of cyber security to their detriment.
- Wireless technologies are still an enigma with a lot more complexity than wired networks
-

MERCURY
INFORMATION SECURITY SERVICES

Qualifying attack surfaces

Wireless systems and why???

Using what is known: NIST CVSS

Need to create a structured method around avenues of approach (NIST CVSS)

- Network
- Adjacent
- Local
- Physical

→

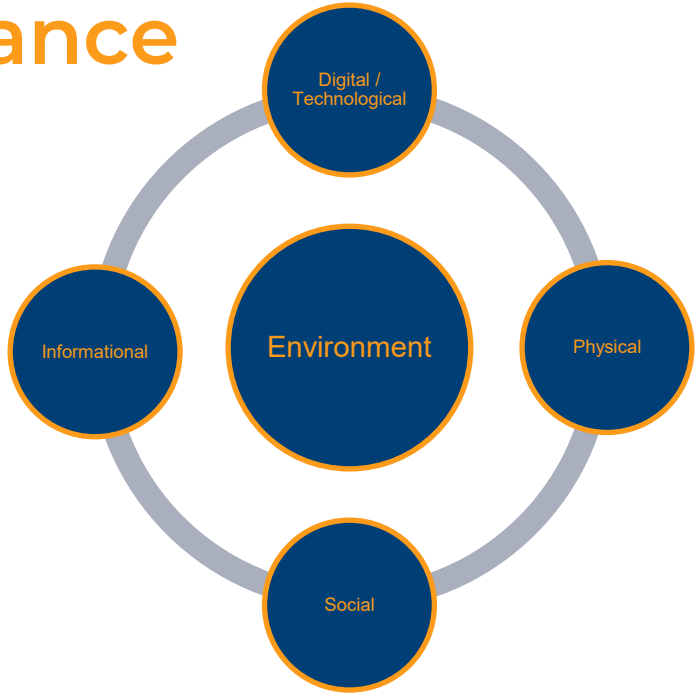
Building out from these:

- Observability
- Key/decisive terrain and supporting effects
- Cover & concealment (technological or social)

→

Questionnaires should not be your only dependency

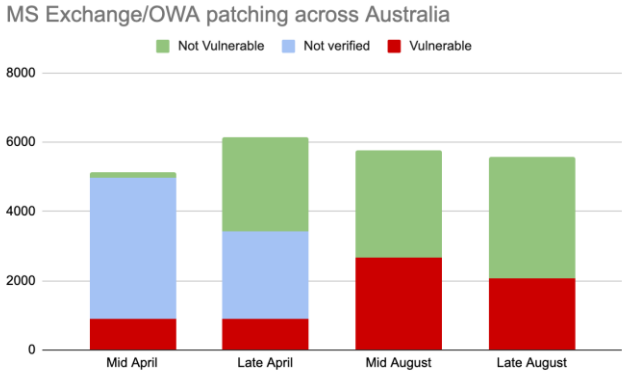
External: basic organisation reconnaissance

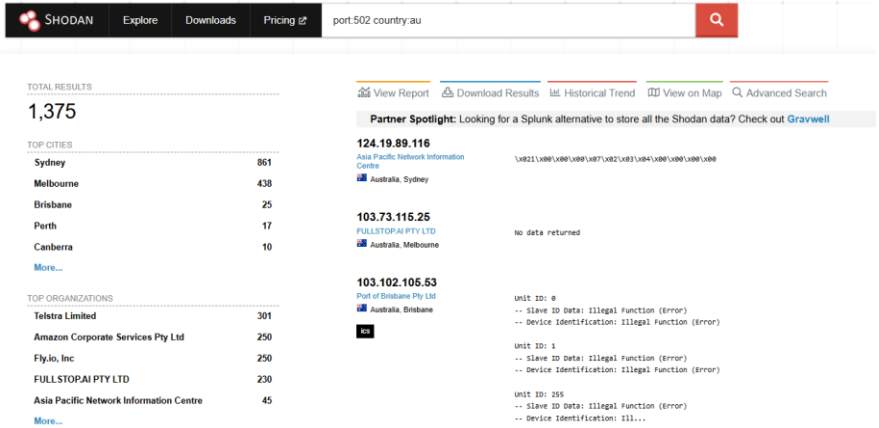


MERCURY
INFORMATION SECURITY SERVICES

External: Internet facing systems and supporting assets

- Digital reconnaissance and attack surface management has been well established for years.
- Personal observation: more “critical infrastructure” is appearing in Australia as honeypots in AWS than legitimate systems in the wild.





AI and ASM is making this harder in a good way

MERCURY INFORMATION SECURITY SERVICES

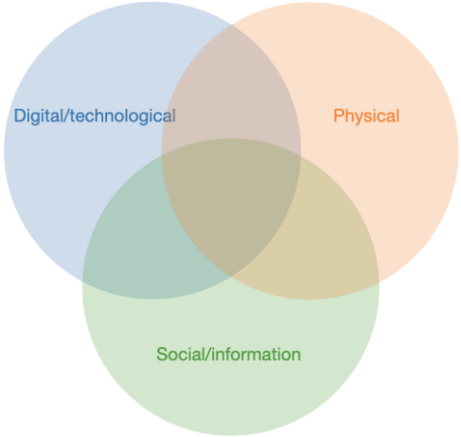
So wireless....

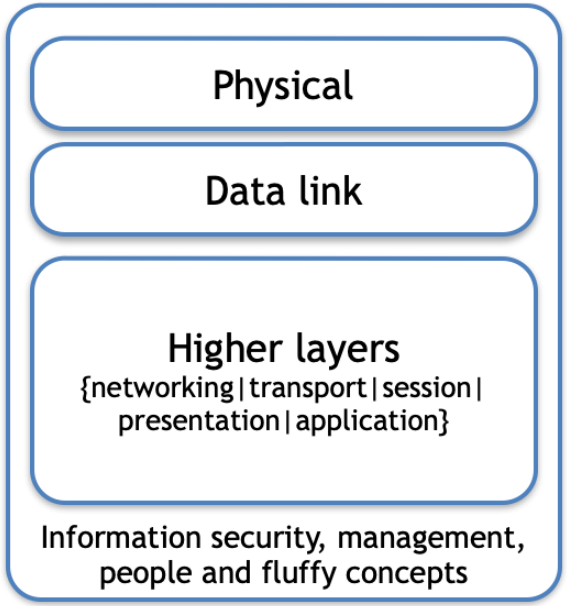
Why is wireless relevant to us in cyberspace?

First two layers of the OSI model

An awesome indicator of where we intersect (which is what cyber is)

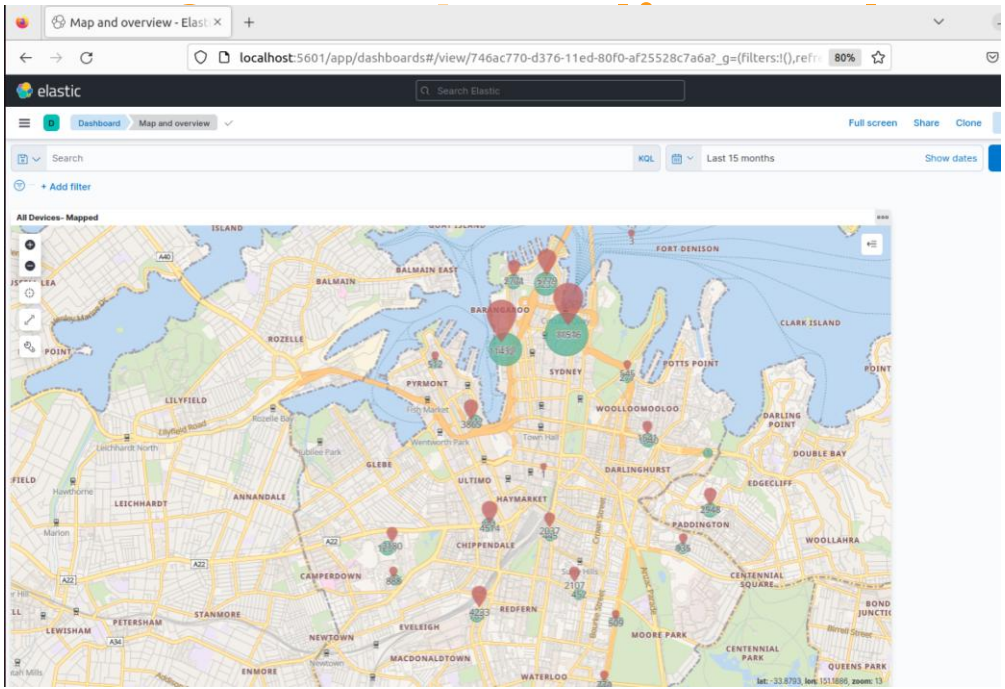
Its another avenue for us to explore

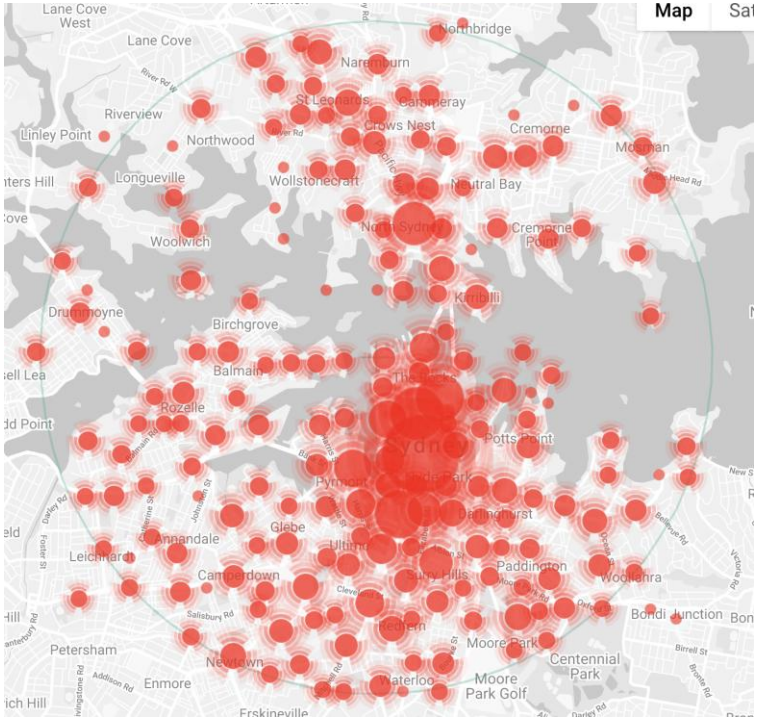




MERCURY
INFORMATION SECURITY SERVICES

Adjacent access: the complex terrain





Over 8000 802.11, 802.15.4 and other sensors collected APR 2023

Current registration of frequencies in Sydney: 27880 licenced transmitters within a 5km radius

MERCURY INFORMATION SECURITY SERVICES

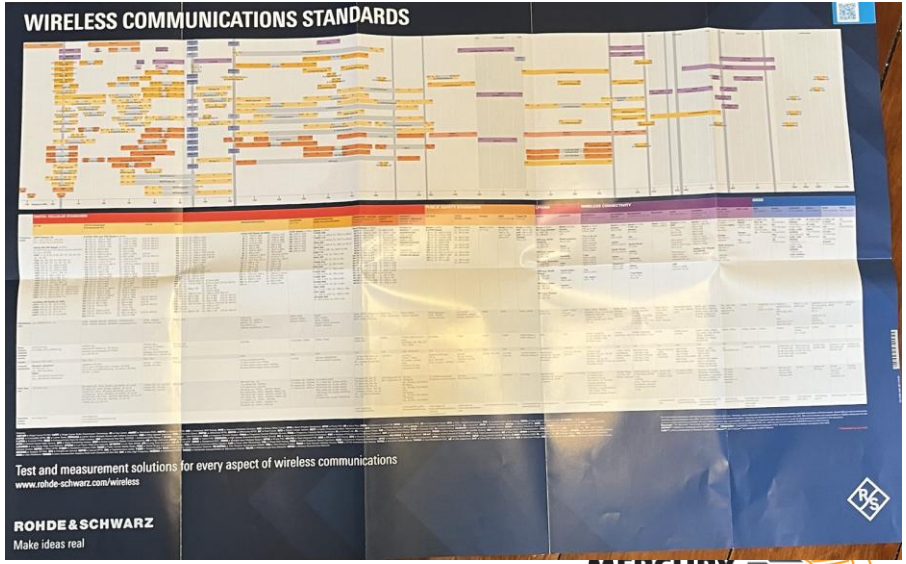
Understanding the spectrum

The radio spectrum is the part of the electromagnetic spectrum with frequencies from 0 Hz to 3,000 GHz (3 THz). (thanks wikipedia)

I'm most interested in 70mhz up to about 3Ghz, although interesting things still either side.

Some of the ISM Bands

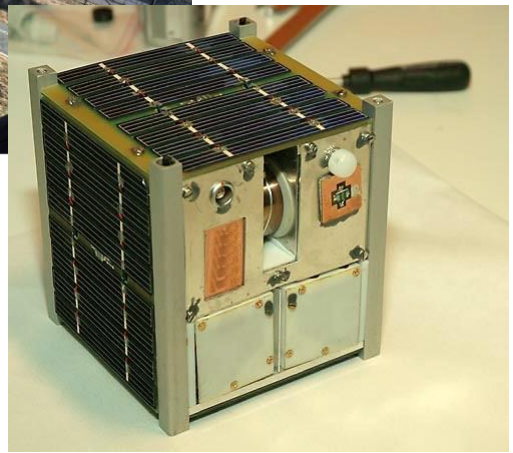
1. 433-435 Mhz
2. 916-928 Mhz
3. 2.4-2.5 Ghz
4. 5.8Ghz



MERCURY
INFORMATION SECURITY SERVICES

Understanding the environment

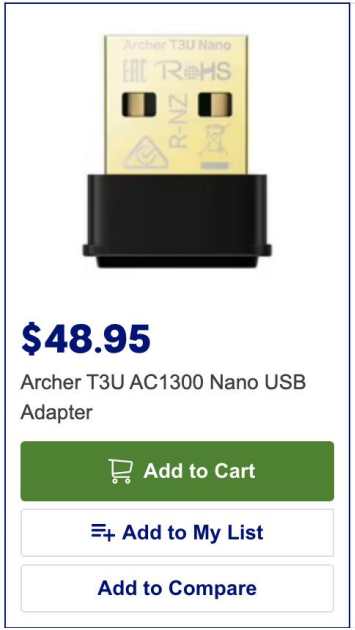
- Commercial
- Building/facilities management
- Maritime
- Logistics & transportation
- Aviation
- Communications
- Personal
- Entertainment
- Security
- Utilities (water, power etc)
- Public alert & communications systems
-



MERCURY
INFORMATION SECURITY SERVICES

Tools

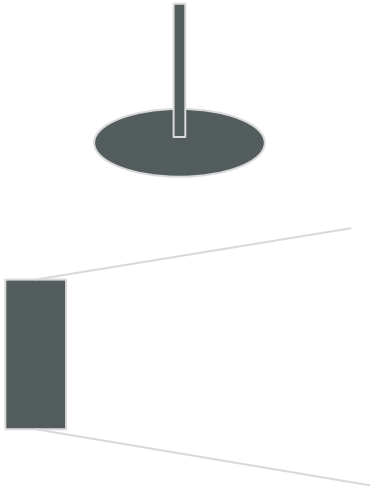
- Please leave your WiFi Pineapple and sense of superiority at home.
- $20 RTL-SDR is usually enough to get started
- A reliable WiFi card like the ones from officeworks is also a good start
- If you're levelling up, Alfa cards, HackRF and others are the way to go
- Some technologies (IE Bluetooth, ZigBee & LoRa) are better executed through dedicated HW.



MERCURY
INFORMATION SECURITY SERVICES

Research and resources to get you started

- Kismet: https://www.kismetwireless.net/
- Aircrack suite: https://www.aircrack-ng.org/
- 802.11 Koutto mind map
- RTL-SDR blog: https://www.rtl-sdr.com/
- Maprad: https://maprad.io/au
- *On power, line of site and antenna theory*
- *HMU if Bluetooth or 802.15.4 is your thing*



MERCURY
INFORMATION SECURITY SERVICES

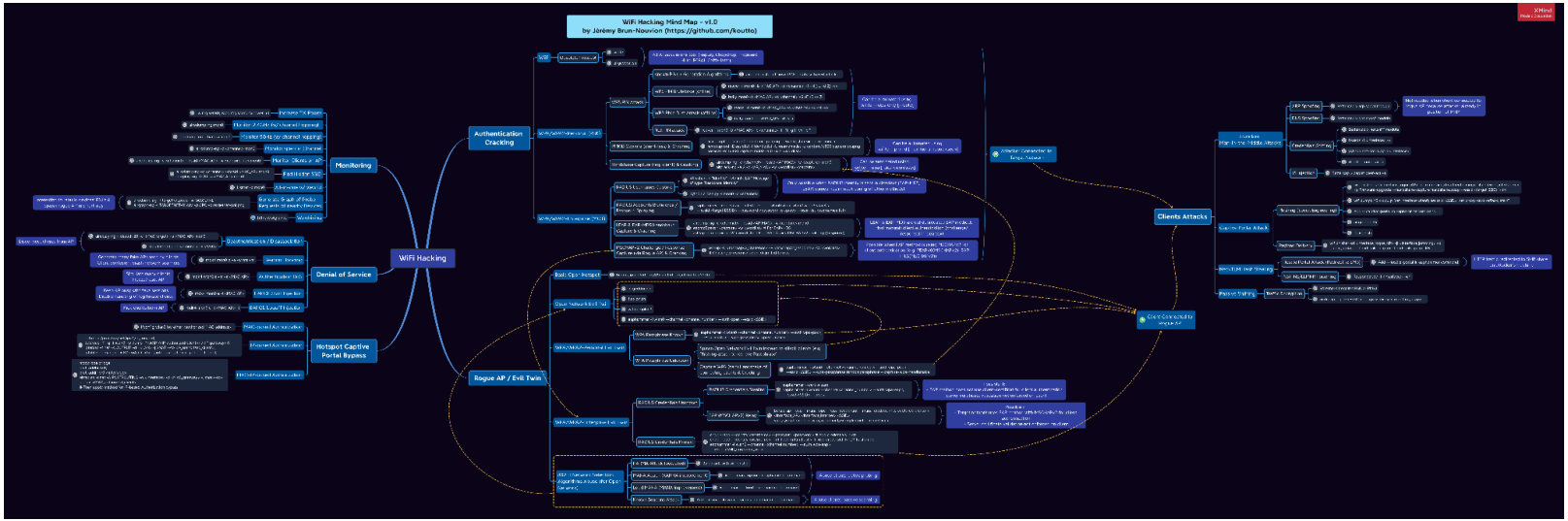
Practical exploration

802.11

- Heaps of wireless networks, who knew right?
- https://wigle.net/
- Gives us an indication of wireless networks over time and their security.
- Client devices are also online, and often beaconing home networks.
- Clear text is still a thing
- 802.11ah and other weird/wonderful standards
- Observations during wireless pentests....

MERCURY
INFORMATION SECURITY SERVICES

802.11, a flow diagram



- Source: https://github.com/koutto/pi-pwnbox-rogueap/blob/main/mindmap/WiFi-Hacking-MindMap-v1.png
-

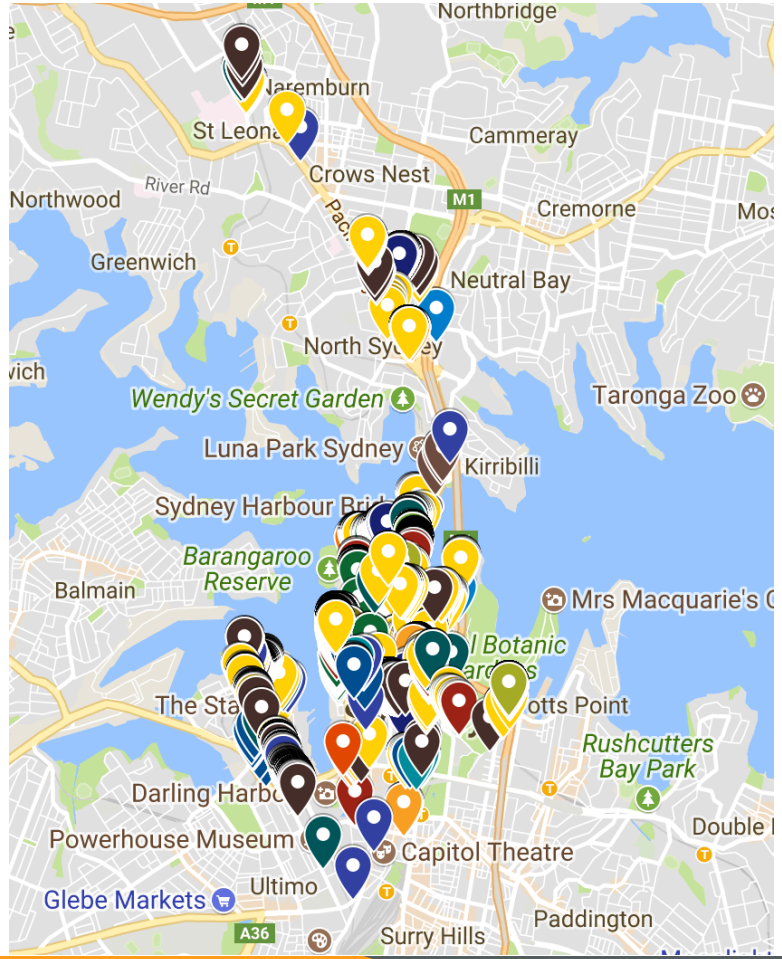
802.15.4

Research project I did in 2018

A lot of new buildings have sensors, locks and control systems all over 802.15.4

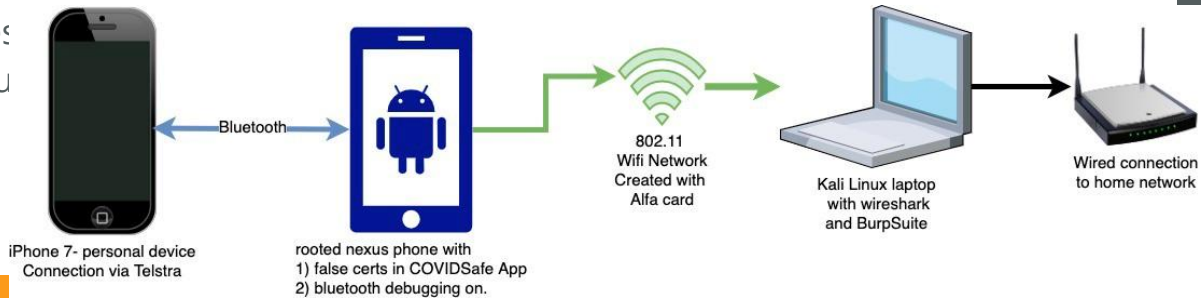
Are these in the risk register?

How easy is it to patch these devices or interface with them



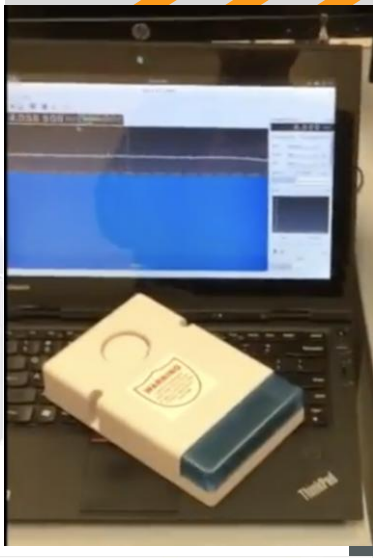
Bluetooth

1. Able to identify unique beacons
2. Capturing (including pairing) is a little harder, however once paired it's hard to get a clean capture.
3. Direction finding also hard but not impossible
4. *Would recommend ESP32 for a bunch of stuff in this space or capturing off your phone.*
5. Interacting with specific devices bluetooth depends on the natu use.



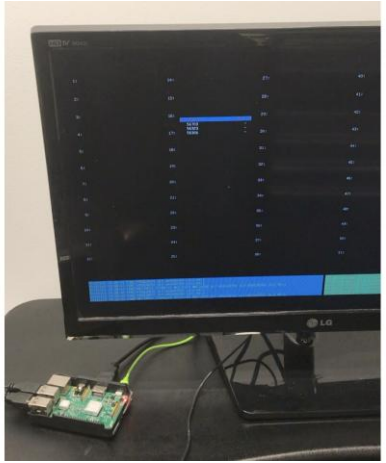
433Mhz

- Tyre pressure sensors
- Temperature/environmental sensors
- Car Keys
- Security devices/electronic keys
- Motion detection systems
- Storage monitors



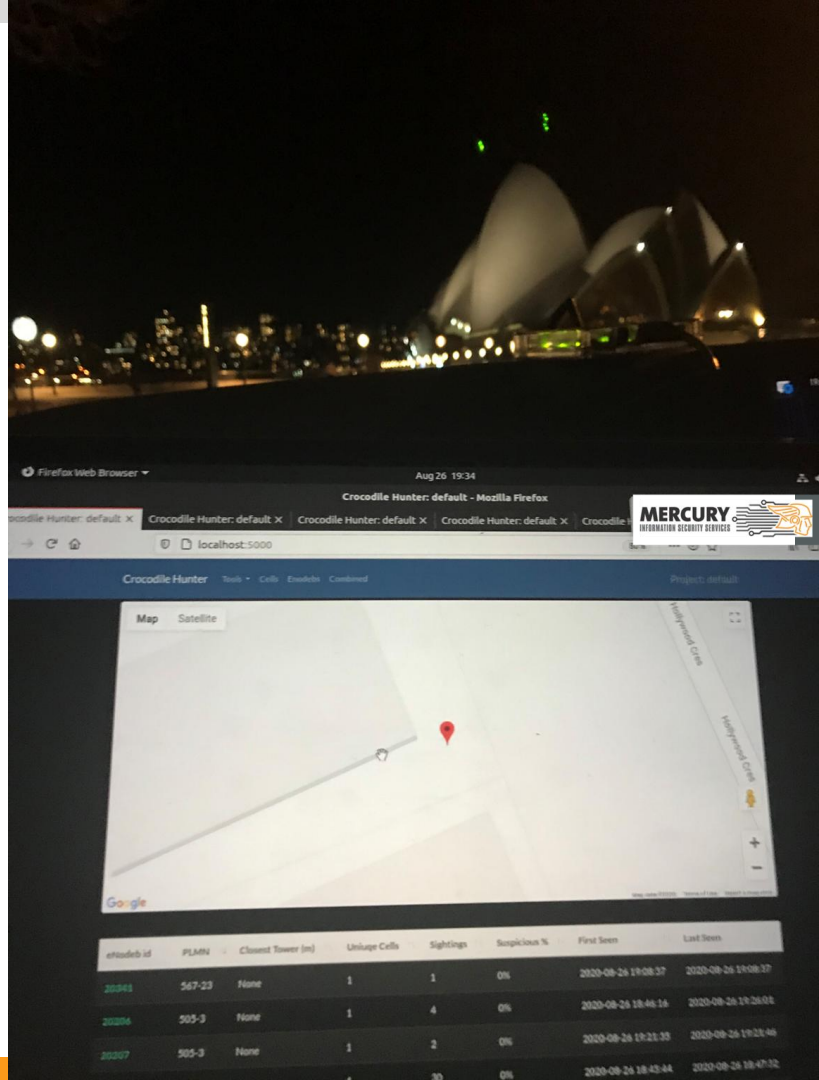
Trunked Radio Networks

1. Capture on this is always a little questionable
2. Data and voice getting transmitted over the link
3. A few of these exist in Sydney...



Cellular networks

1. Fun project- mapping out cell towers in Sydney
2. *Note- 5G cannot capture voice, but can at least discover cell towers.*
3. Correlation with known data (maprad) and what's out there.
4. People creating their own cell towers for fun.



Others

- ADSB & ACARS
- AIS
- POCSAG
- LORA
- Restaurant Pagers
- Space/Satellites
- DECT
- Drones?

MERCURY
INFORMATION SECURITY SERVICES

Others

- RFID
- TETRA
- DECT
- MOBITEX (limited use)
- P25
- Paging networks (IE, FLEX, POCSAG, ERMES)
- Radiosonde
- Public alert systems (EAS)
- Aircraft specific (IE GBAS, ACARS or ADSB)
- Maritime specific (IE, AIS or UHF)

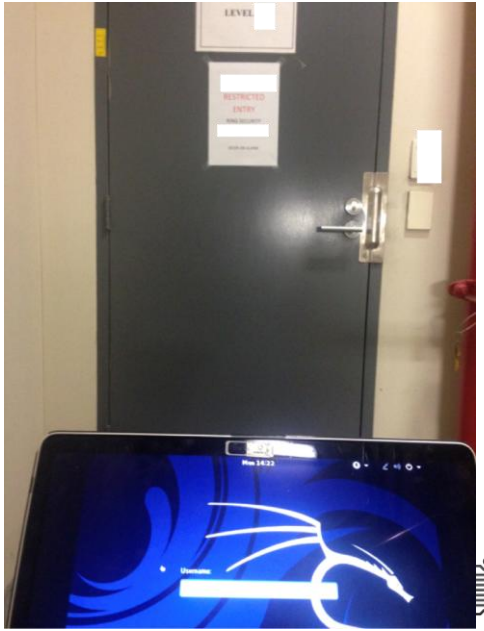
MERCURY
INFORMATION SECURITY SERVICES

During client engagements

Thinking about range and location

Are there physical security assumptions that have been made?

How are security controls mutually assured?

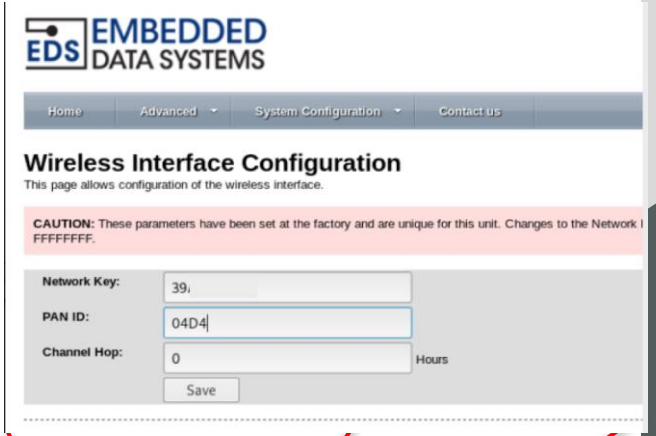


Facilities

Facilities temperature monitors.

Started to identify patterns, RSSI and no changes in packets.

The HTTP interface on the bridge just gives you the key anway.



MERCURY
INFORMATION SECURITY SERVICES

Keyboards

```
0  » hid.s[19:19:31] [sys.log] [inf] hid payload for d1:4c:90:ab:07 : 00000000  00 51 07 09 00 64 00 00  06 d7 47 4f 44 00 00  |.Q...d....GOD..|
0010  00 00 00 00 00 35                                          |.....5|
0  » hid.s[19:19:31] [sys.log] [inf] hid payload for d1:4c:90:ab:07 : 00000000  00 40 04 1a a2                          |.@...|
0  » hid.sniff [19:19:32] [sys.log] [inf] hid payload for d1:4c:90:ab:07 : 00000000  00 40 04 1a a2                      |.@...|
0  » hid.sniff [19:19:33] [sys.log] [inf] hid payload for d1:4c:90:ab:07 : 00000000  00 40 04 1a a2                      |.@...|
0  » hid.sniff [19:19:36] [sys.log] [inf] hid payload for d1:4c:90:ab:07 : 00000000  00 40 04 1a a2                      |.@...|
0  » hid.sniff [19:19:40] [sys.log] [inf] hid payload for d1:4c:90:ab:07 : 00000000  00 40 04 1a a2                      |.@...|
0  » hid.sniff [19:19:43] [ble.device.new] new BLE device detected as 4B:81:7F:52:71:44 (Apple, Inc.) -92 dBm.
0  » hid.sniff [19:19:44] [sys.log] [inf] hid payload for d1:4c:90:ab:07 : 00000000  00 d3 65 b1 ed b2 92 9f  d4 50 4f 24 9e 38 00 00  |..e......PO$.8..|
0010  00 00 00 00 00 da                                           |......|
```

Monitor and inject

Rest of the network was fine... however it was possible to collect passwords.

MERCURY
INFORMATION SECURITY SERVICES

A worked example: port botany

Why port botany?

Armatures study conflict, professionals study logistics

1. Closest port in proximity to Sydney CBD
2. One of three major ports close to 20% of Australia's population
3. One of only a few bulk liquid terminals in Australia
4. What happens when logistics and shipping are clogged up?
5. Proximity to Sydney airport and second order impacts
6. It was close to home to me and appeared to be the easiest research target due to its size and scale

MERCURY
INFORMATION SECURITY SERVICES

Digital Reconnaissance & external attack surface:

Lots, but key ones include:

1. NSW Port Authority
2. Ports NSW- Ship Tracking and Noise Tool
3. Pacific National
4. DP World
5. QENOS PTY LTD
6. Medlog
7. Elgas
8. Newcastle Ports
9. Department of Home affairs
10. Patrick Stevedores Operations Pty Ltd
    1. Cloud environment
    2. VPN
    3. Directly accessible SMTP

- BLUF: Our external attack surfaces are reducing.... Kind of (and based on what we can verify with limited recon)

- Assumption: We're reducing directly attackable systems on the internet. So what's next?

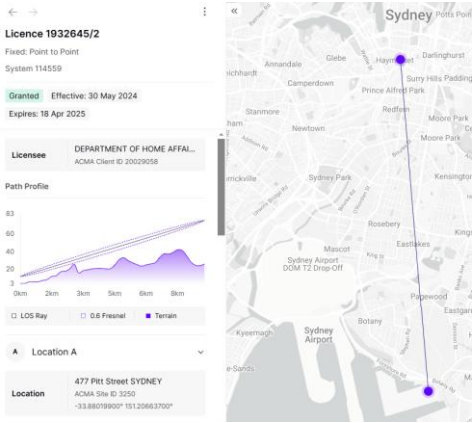
  Support systems... and systems of systems

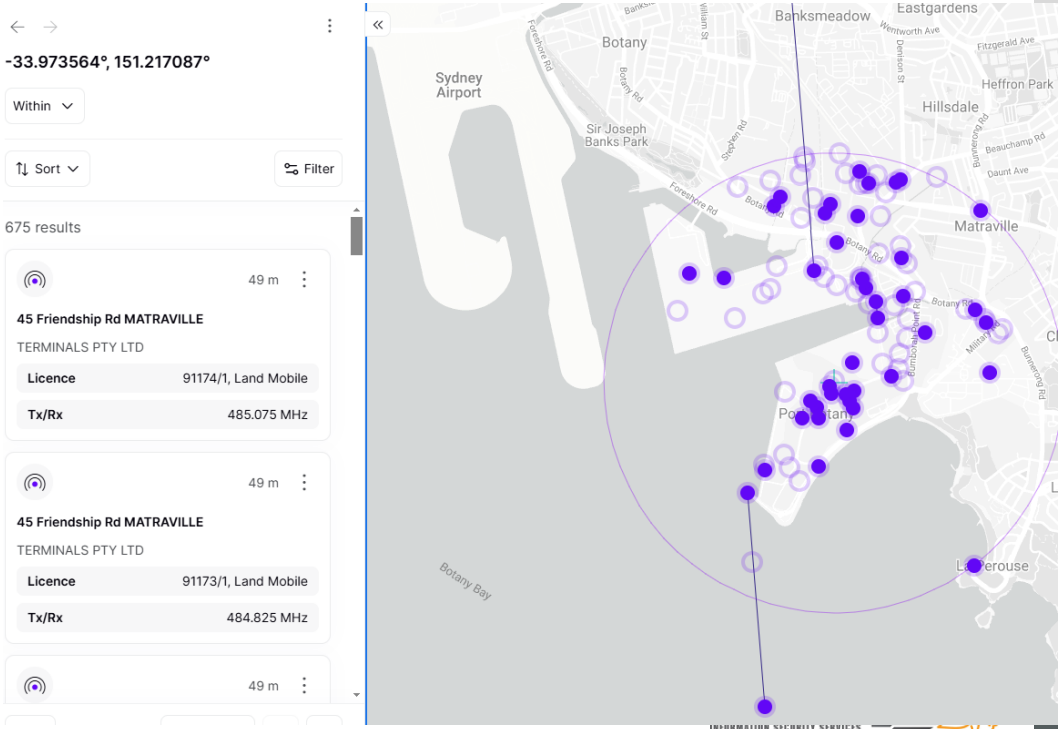
MERCURY
INFORMATION SECURITY SERVICES

Registered radiofrequencies within range

- Revisiting EW Concepts

1. Intercept (pattern of life analysis)
2. DF
3. Disrupt and jam





Wireless wardriving

- IOT is becoming a big thing. Does this enable an attack vector?
- Summary statistics:

- 753 Wireless access points
- 142 other items of supporting infrastructure
- 22 Ad Hoc (personal networks)
- 870 Bluetooth devices
- 504 Wireless devices
- 2x ZigBee devices
- 1x TPMS

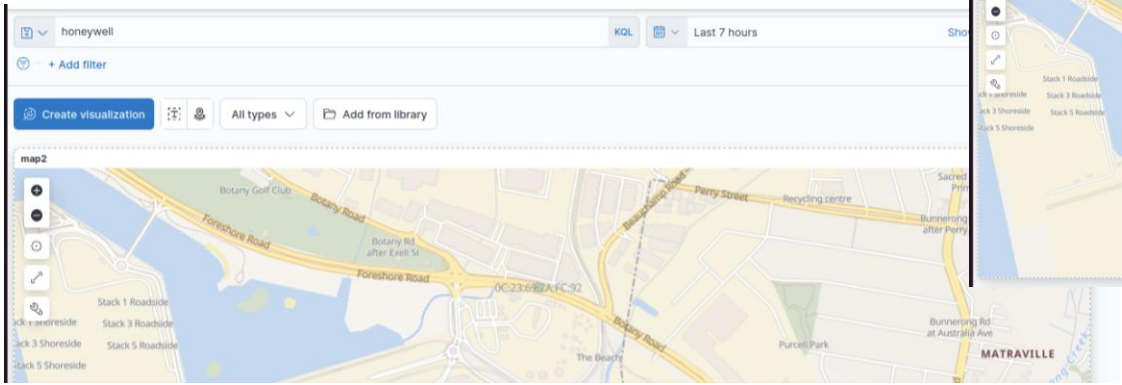
- *Only 30 mins… and I reckon there's more*

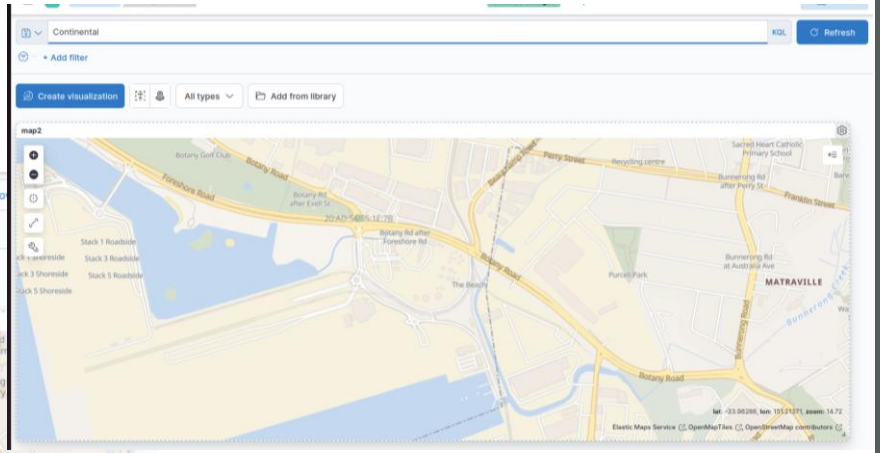
MERCURY
INFORMATION SECURITY SERVICES

Observation: BTLE enabled card readers

MERCURY
INFORMATION SECURITY SERVICES

Observation: known automation systems… and mapping manufacturing networks





MERCURY
INFORMATION SECURITY SERVICES

Continued

21 hits

Chart options

Nov 10, 2024 @ 12:43:27.729 - Nov 10, 2024 @ 13:12:12.833

Time	kismet_device_base_commonname	kismet_device_base_manuf	kismet_device_base_crypt
Nov 10, 2024 @ 13:09:11.000	00:20:4A:FA:54:2F	Pronet GmbH	(empty)
Nov 10, 2024 @ 13:09:04.000	00:20:4A:FA:53:84	Pronet GmbH	(empty)
Nov 10, 2024 @ 13:09:04.000	00:20:4A:9D:CF:AE	Pronet GmbH	(empty)
Nov 10, 2024 @ 13:09:04.000	00:20:4A:FA:53:AE	Pronet GmbH	(empty)
Nov 10, 2024 @ 13:09:04.000	00:20:4A:D6:C2:40	Pronet GmbH	(empty)
Nov 10, 2024 @ 13:09:03.000	00:20:4A:F9:B0:7C	Pronet GmbH	(empty)
Nov 10, 2024 @ 13:03:48.000	00:20:4A:9D:F0:10	Pronet GmbH	(empty)
Nov 10, 2024 @ 12:57:50.000	00:20:4A:FA:53:B5	Pronet GmbH	(empty)

MERCURY
INFORMATION SECURITY SERVICES

Others & considerations

1. Safety equipment
2. Weighing stations
3. Bluetooth enabled driver behavior management devices
4. Dash cams
5. Disparate smart ecosystems
6. ESP32 microcontrollers and other MAC addresses
7. Time to analyze and develop
8. Sample size and reliability of wardriving system
    1. Antennas and what is in site?

MERCURY
INFORMATION SECURITY SERVICES

Others

Other: a critical infrastructure site

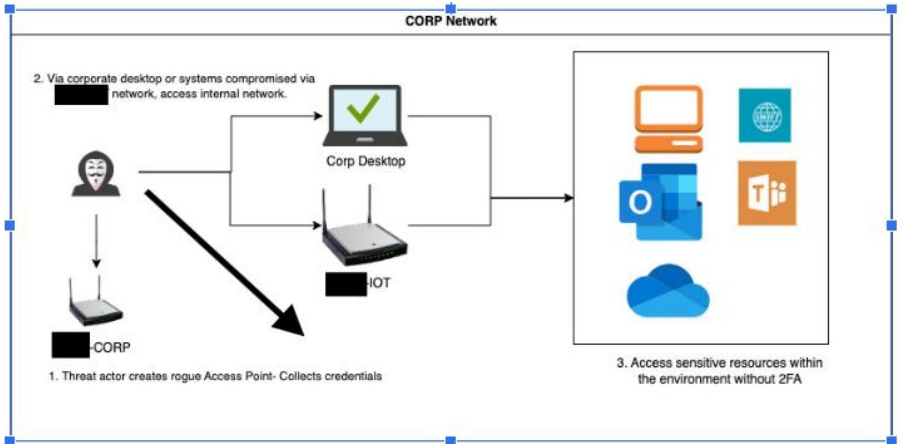
- Insecure protocols
- Able to interact with OT and air conditioners
- Windows terminals

... did not do any active exploitation

MERCURY
INFORMATION SECURITY SERVICES

Wireless in the attack path

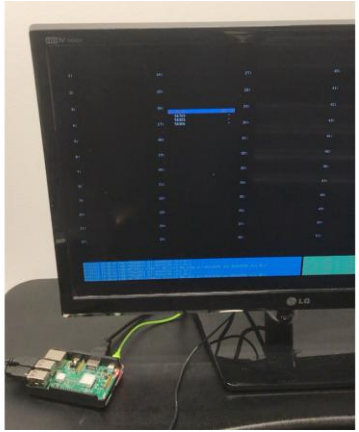
- SSO and federated identity....
- With 2FA turned off -→ AWS and other accesses



MERCURY
INFORMATION SECURITY SERVICES

Other: Hunting comms in IIOT

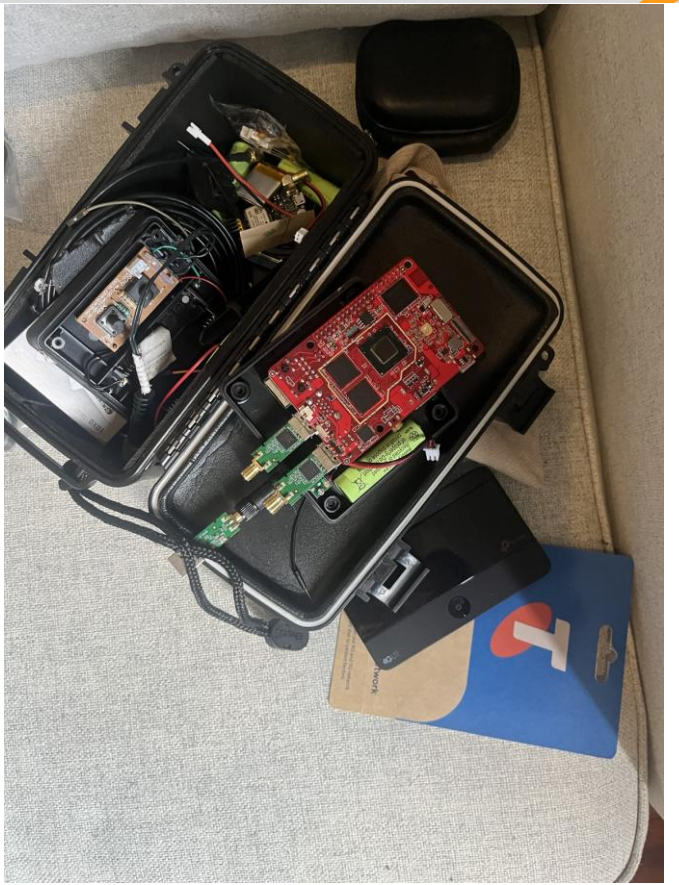
- 200+ devices on WPA2 PSK
- Can identify virtual system and manufacturing data
- Trunked radio network with security



MERCURY
INFORMATION SECURITY SERVICES

Future projects

- 4G cell tower hunting
- Mystery wardriving project



MERCURY
INFORMATION SECURITY SERVICES

Questions?

edward.farrell@mercuryiss.com.au